

IP cookie binding in Dataverse

Built by: Power CAT

This module walks you through IP address-based cookie binding — a Managed Environments feature that protects Dataverse against cookie replay attacks by binding each session cookie to the IP address it was issued to, and rejecting any request where the two no longer match.

Labs in this module

Lab	Description
Understand IP cookie binding	Learn how a cookie replay attack works and how cookie binding stops it in real time
Enable IP cookie binding	Turn on the setting for a managed environment in the Power Platform admin center

Prerequisites

1. You have a Power Platform environment with **Managed Environment** enabled — this feature is not available for environments that are not managed.
2. You have access to the environment's settings in the [Power Platform admin center](#), under **Settings > Product > Privacy + security**.

Business use case

Woodgrove Bank's managed-security program has closed two findings so far: the sales environment is encrypted with the bank's own key ([Customer-managed keys \(CMK\)](#)), and it can only be reached from the bank's approved IP ranges ([IP firewall in Dataverse](#)). The final finding from the security review targets a subtler layer: the session itself.



The earlier modules are part of the same storyline, but they are not prerequisites — this module stands alone, and you can complete it without any other module in the series.

During a red-team exercise, testers demonstrate that a session cookie lifted from a signed-in workstation — through malware, a browser exploit, or simply an unlocked machine — can be copied to a second device and replayed against Dataverse. The stolen cookie is valid, so the platform treats the attacker as the user who signed in. No password is cracked, no sign-in prompt appears, and multifactor authentication never triggers, because authentication already happened on the victim's machine.

The IP firewall narrows the attack surface but doesn't eliminate it: a replay launched from another machine *inside* the allowed corporate ranges would still get through. The risk team's requirement is therefore defense in depth at the session layer:

- **Bind each session to its origin.** A cookie should only work from the IP address it was issued to; anywhere else, it is evidence of theft.
- **Reject replays in real time.** Detection after the fact is not enough — the replayed request itself must fail, before any data is returned.

- **Alert the administrators.** A rejected replay is a security signal; the admin team wants to know a stolen cookie is in play.

IP cookie binding delivers exactly this. In this module, you first walk through the mechanics of the attack and the defense, and then enable the feature on the sales environment.

What you learn

By the end of this module, you can:

- Explain what a cookie replay attack is and how it can be used to impersonate a signed-in user.
- Describe how IP cookie binding evaluates the IP address associated with each request to detect a replayed cookie.
- Explain how Dataverse decides whether to return a response when the feature is enabled, and what happens when the check fails.
- Enable IP address-based cookie binding for a managed environment in the Power Platform admin center.



Ready to get started? Go through the labs table above in order — the concepts in the first lab explain what the switch in the second lab actually does.